

really dangerous thing about it is that the backdoor it opens allows for root-level access to the infected machine and permits any code to be executed, thus making the machine a potential zombie.

Most of the world appears to have patched up against CR and CRv2. But the Code Red story doesn't end here—there still exist systems that are vulnerable, ready to infect others, waiting.

Target the roots

The internet today relies on 13 crucial DNS (Domain Name Service) root servers that act as a sort of main directory service for routing packets across the Internet to make sure they reach the correct machine. The central 'A' DNS server is operated by Network Solutions Inc, and this server maintains the master list of all top level domain names (such as .com, .org, .net, .mil and country-specific codes). This list is duplicated in the 12 other root servers on a daily basis (the servers are designated 'A' through 'M'). The list is made available to all routers across the Internet, and routing tables are updated by referring to the lists in the root servers. For example, this is what converts www.google.com to its respective IP address, and lets you locate a machine's location through its domain. Now, to ensure redundancy, and to make sure that all the root servers don't get taken down by the same natural or unforeseen calamity, the servers are dispersed globally, in places as far apart as Stockholm, London, Tokyo and Maryland. They are monitored by the US government agencies, as well as research organisations and universities, they are variously defined as 'battle hardened' and 'equipped to live through attacks of all sorts'—or so they wish.

On the 21st of October 2002, nine of the thirteen root servers showed how vulnerable they were. In an attack that lasted just over an hour, a major distributed DoS attack was mounted on the root server system worldwide. The root DNS servers have been attacked before and subjected to DoS attacks, however what made this different, and more serious was the fact that all the root DNS servers had never been targeted at the same time before. The attack itself came as a huge ICMP flood. ICMP, the Internet Control Message Protocol, is a system designed to carry error reporting or testing data. To put it simply, what happened was a ping-style flood that was used to clog up the access lines, and eat up all available bandwidth, so that all legitimate data packets got lost.



Jargon Buster

Zombies: Zombies are computers that have been taken over by a remote attacker, and are used to attack other computers.

Ports and port number: A port is a termination point on a network. Port numbers allow different processes and programs to use network resources without interference.

Buffer Overflow: Programs allocate fixed size blocks called 'buffers' for reading data. If a program is given too much data that it reads into the buffer without checking the size, the buffer overflows leaking the data into neighbouring memory. This could potentially overwrite the program code, and the computer may execute the overflowing data as a part of the instructions. If the exploited buffer sits

in a privileged program, a malicious program could take full control of the computer.

Stack Overflow: A program stack is a block of memory that holds the list of functions to be executed. If a programmer isn't careful, it is possible for a hacker to send a large packet of data that overwrites the stack, and executes functions that the hacker wants. If the exploited stack sits in a privileged program, a malicious program could let an intruder take full control of the computer.

Backdoors: Malicious programs that let intruders access a computer system. These programs may, for example, modify important system tools that would let a hacker access the computer at a later date.

Fortunately though, two things came to the rescue of the Internet. The first was the fact that most DNS query data does not reach the root servers—instead, caching techniques are used, meaning that actually consulting the root servers is generally the last resort. The second was the fact that server administrators quickly realised that the attack was an ICMP data flood, and hence shut down those services. Yet, nine of the root servers were overwhelmed in the attack and succumbed. But reports at the time indicated that since the attack was short-lived, most users on the Internet never came to know about the outage in service. On the flip side, most analysts agree that the attack had indeed continued for several hours, then with the DNS caches slowly expiring the world over, no top-level domain name conversions would have taken place through the root servers, and users would have been snapped out of the online link. The 'F' root server, for example, responds to over 270 million DNS queries every day. To put it in perspective, we were plain lucky that the 'most sophisticated, large-scale assault in the history of the Internet' stopped with just this much damage—but we could expect worse in the future.

Hindsight, 20:20

DoS attacks today have become very sophisticated; the time, kind and duration of the attack, and the victim's IP address are now programmed into an attack mechanism or code. The fact also is that the acquisition and infection phase is pretty sophisticated, and that's why, once a host has been taken over, the popula-

tion of infected machines enlarged.

The Code Red and Slammer attacks have targeted specific known vulnerabilities in application software. This is certainly not the only way to attack and take over machines, but the most successful attacks in recent times have been of this type. With more and more vulnerabilities being identified in common application software, the likelihood of worms that target them is definitely going to increase. And Brute force attacks, such as the October 2002 DNS root server attack, can always be done.

If you believe that switching over to open source solutions is a remedy, think again—the problem lies not with the kind of software, but with how well informed and how well-patched up you are. Both open source, as well as proprietary solutions, have shown vulnerabilities, and this does not take into account attacks that target bugs and features in protocols. In both the Code Red and the Slammer worm attacks, critical patches were available before the attacks took place, yet the spread of the worms in both cases was astonishingly fast—showing that a vast number of servers had not been patched. And here's some more food for thought: News.com reported over two years back, that over 4,000 DoS attacks hit the Internet every week. Now that is scary. With all of four billion hosts on the Internet, how big is this statistic going to be in the next few years? More importantly, will you be yet another number in a table? ■

SRINIVASAN RAMAKRISHNAN
srinivasan_ramakrishnan@jasubhai.com